

MEDSPA STANDARDS

PROTOCOL KIT

Operations & Compliance

Five foundational documents covering the oversight, records, staffing, safety and privacy obligations that sit underneath every clinical service you offer.

5 SOPS · VERSION 1.0 · EFFECTIVE JANUARY 2026

Contents

OPS-001	Medical Director Oversight & Delegation The delegation structure, standing orders and chart review that every clinical protocol depends on
OPS-002	Patient Intake, Consent & Medical Records What intake must capture, how consent is obtained, and how charts are written, corrected and retained
OPS-003	Scope of Practice, Credentialing & Training Verifying who may do what, proving they were trained, and keeping it current
OPS-004	Infection Control, Sterilization & Sharps Hand hygiene, instrument reprocessing, spore testing, sharps handling and exposure response
OPS-005	HIPAA, Privacy & Marketing Compliance Safeguards, breach response, before-and-after images, testimonials and advertising claims

Before you put these into service

1. Have a licensed healthcare attorney in your state review OPS-001 before any medical director agreement is executed.
2. Complete the delegation matrix in OPS-003, service by service, and have the medical director sign each line.
3. Populate the record retention schedule in OPS-002 against your state's rules.
4. Start the spore testing and cycle logs in OPS-004 this week — they only prove anything going forward.
5. Audit existing marketing images against the authorization standard in OPS-005 and remove anything unsupported.

OPERATIONS & COMPLIANCE

Medical Director Oversight & Delegation

The delegation structure, standing orders and chart review that every clinical protocol depends on

DOCUMENT OPS-001	VERSION 1.0	EFFECTIVE January 2026	REVIEW CYCLE Annual
APPLIES TO Medical director, owner, practice manager	OWNER Medical Director	CLASSIFICATION Confidential	SUPERSEDES All prior versions

1 Purpose & Scope

This is the foundation document. Every clinical protocol in the practice operates under the delegation authority and standing orders defined here. It sets out the medical director's duties, the mechanism by which clinical tasks are delegated, the chart review obligation, and the annual re-authorization cycle that keeps all of it current.

READ THIS BEFORE ANYTHING ELSE

A signed clinical SOP is only meaningful if the person who signed it has a documented oversight relationship with the practice and the authority to delegate the tasks inside it. If OPS-001 is incomplete, every other protocol in your binder is floating.

LEGAL REVIEW REQUIRED

Medical director agreements, ownership structures and delegation arrangements carry corporate practice of medicine implications that differ sharply between states — including whether a non-physician may own the practice at all, and whether a management services organization is required. **This template must be reviewed by a licensed healthcare attorney in your state before execution.** It is designed to make that review faster, not to replace it.

2 Medical Director Agreement — Required Elements

A one-page contract naming a physician and a monthly fee is the arrangement most commonly found in practice and the one least likely to withstand scrutiny. The agreement should address each element below.

AGREEMENT CHECKLIST

Element	What it must specify
Parties and licensure	Full legal names, the physician's license number and state, specialty, and confirmation of good standing verified at execution.
Scope of oversight	Which service lines and locations the medical director is responsible for. Silence here is read as everything.
Duties	Protocol authorship and approval, standing orders, chart review, staff competency sign-off, adverse event review, and complaint involvement — each stated explicitly.
Time commitment	Defined hours or a defined cadence of activity. A retainer with no stated activity is the weakest possible arrangement.
Availability and response	How the medical director is reached during clinic hours, expected response time, and who covers absence, vacation and after-hours.
On-site presence	Whether physical presence is required for any service, and at what frequency — state-dependent and must be reconciled with your state's rules.
Compensation	Structure and basis. Fee arrangements tied to treatment volume or revenue raise fee-splitting and anti-kickback concerns in many jurisdictions — flag for legal review.
Term, renewal and termination	Including notice period and an orderly transition obligation so services do not continue unsupervised during a handover.
Insurance	Malpractice coverage carried by each party, limits, and tail coverage on termination.
Records access	Confirmation that the medical director may access any patient record at any time.

3 Standing Orders & Delegation

Standing orders are the mechanism that permits staff to perform clinical tasks without an order for each individual patient. They are specific, written, signed and dated — a general statement that the medical director approves the practice's activities is not a standing order.

Requirements for a valid standing order

- Names the specific procedure, medication or intervention authorized.
- Names the role authorized to perform it, and the minimum license or credential required.
- States the patient criteria under which it may be performed, and the exclusions.
- States the circumstances requiring escalation to the medical director before proceeding.
- Is signed and dated by the medical director, with a stated review date.
- Is reconciled against your state's scope of practice and supervision rules.

DELEGATION IS TASK-BY-TASK

Authorization is granted for a specific task to a specific role, not to a person in general. A registered nurse authorized to administer neurotoxin is not thereby authorized to assess candidacy, to treat a complication, or to operate a laser. Build the matrix in OPS-003 and have the medical director sign it line by line.

Annual re-authorization

- ☐ Every clinical protocol reviewed and re-signed by the medical director annually.
- ☐ Standing orders reviewed against current clinical guidance and any change in state rules.
- ☐ Delegation matrix reviewed against current staffing and license status.
- ☐ Superseded versions retained rather than destroyed — you may need to show what was in force on a given date.
- ☐ Review date, participants and outcomes recorded in the oversight log.

4 Chart Review

Chart review is the activity that converts a nominal oversight relationship into a demonstrable one. It is also the single most commonly omitted medical director duty.

Element	Standard
Cadence	Set a defined interval — monthly is common. Record it in the agreement rather than leaving it to judgement.
Sampling method	Define how charts are selected: a percentage of total volume, a fixed number per provider, plus all adverse events and all new providers during their supervised period.
What is reviewed	Candidacy documentation, consent, treatment record completeness, product and lot recording, aftercare, and follow-up closure.
Findings	Recorded in an oversight log with the charts reviewed, issues identified, and corrective actions assigned.
Follow-through	Corrective actions verified complete at the next review. An unclosed action is worse than no review.
Escalation	Any pattern suggesting a competency gap triggers the process in OPS-003 rather than an informal conversation.

5 Oversight Records to Retain

- ☐ Executed medical director agreement, plus all superseded versions.
- ☐ Current license verification with the date checked and re-verification at each renewal.
- ☐ Malpractice certificate of insurance for the medical director, current and on file.
- ☐ Every signed clinical protocol with its authorization page completed.
- ☐ Signed delegation matrix, current version plus prior versions.
- ☐ Chart review log with findings and closed corrective actions.
- ☐ Adverse event reviews with the medical director's documented involvement.
- ☐ Annual protocol review sign-off for each year the practice has operated.

THE FIVE-MINUTE TEST

One named person should be able to produce all eight items above within five minutes of being asked. If that is not true today, that gap is your first corrective action.

6 Quick Reference

QUICK REFERENCE CARD

Oversight essentials

1. **Agreement** — executed, specific duties, verified license, insurance on file.

2. **Standing orders** — task-specific, role-specific, signed and dated.

3. **Delegation matrix** — line-by-line, reconciled to state scope rules.

4. **Chart review** — defined cadence and sampling, findings logged.

5. **Corrective actions** — assigned with an owner and closed out.

6. **Annual re-authorization** — every protocol re-signed, prior versions retained.

7. **Legal review** — attorney sign-off before execution, not after.

Print, laminate and post at the point of care

7 Medical Director Authorization

This protocol is adopted as a standing order for the practice named below. By signing, the medical director confirms the protocol has been reviewed against current clinical guidance, applicable state scope-of-practice rules, and the training level of the staff authorized to perform it.

PRACTICE NAME

LOCATION / SITE

MEDICAL DIRECTOR — PRINTED NAME & CREDENTIALS

LICENSE NUMBER & STATE

SIGNATURE

DATE ADOPTED / NEXT REVIEW DATE

Template notice. This document is an editable template provided for educational and operational guidance. It is not legal advice, does not constitute a physician–patient relationship, and does not guarantee regulatory compliance or the outcome of any inspection. Drug doses, concentrations and device settings must be verified against current manufacturer labeling and prevailing clinical guidance before use. A licensed medical director must review, customize and sign this protocol before it is placed into service, and must confirm that every task assigned within it falls inside the scope of practice of the personnel performing it in your state.

© MedSpa Standards. Licensed for use within the purchasing practice only. Redistribution or resale is prohibited.

OPS-001 Medical Director Oversight & Delegation — MedSpa Standards v1.0 · January 2026

Page 4 of 4

OPERATIONS & COMPLIANCE

Patient Intake, Consent & Medical Records

What intake must capture, how consent is obtained, and how charts are written, corrected and retained

DOCUMENT OPS-002	VERSION 1.0	EFFECTIVE January 2026	REVIEW CYCLE Annual
APPLIES TO All clinical and front-of-house staff	OWNER Medical Director	CLASSIFICATION Confidential	SUPERSEDES All prior versions

1 Purpose & Scope

This protocol governs the information collected before treatment, the consent obtained for it, and the record made of it. These three things are what a board, a carrier or an attorney will read first — and in most disputes the chart is the only witness that is still available.

WRITTEN FOR THE READER WHO WAS NOT THERE

A chart entry is written for someone reviewing it two years later with no memory of the visit. If an entry would not tell that reader what was assessed, what was done, what was used and what the patient was told, it is incomplete.

2 Intake — Required Elements

Category	Must capture
Identity and contact	Legal name, date of birth, address, phone, email, emergency contact, and photo ID verification for controlled substance or prescription services.
Medical history	Current conditions, past surgical history, hospitalizations, and pregnancy or breastfeeding status where relevant to the service.
Medications	All prescription, over-the-counter, supplement and herbal products, with particular attention to anticoagulants, immunosuppressants, photosensitizing agents, isotretinoin and GLP-1 therapy.
Allergies	Drug, latex, food and topical allergies with the reaction described — not just the substance named.
Aesthetic history	Prior treatments, products used, dates, providers, and any prior complication or unsatisfactory result.
Service-specific screening	The screening questions required by the relevant clinical protocol — fainting history, keloid tendency, Fitzpatrick type, HSV history, implanted devices, and so on.
Goals and expectations	In the patient's own words. This is the single most useful entry when a result is later disputed.

UPDATE, DO NOT ARCHIVE

Intake is not a one-time form. Medications, pregnancy status, recent sun exposure and new diagnoses change between visits. Re-confirm at every appointment and record the confirmation — a blank field is not evidence that nothing changed.

3 Informed Consent

Consent is a conversation that is then documented, not a signature collected at the front desk. Each service category needs its own consent addressing the risks specific to it.

Required elements of every consent

- The specific procedure, area to be treated, and product or device to be used.
- The expected outcome, and explicitly that results vary and are not guaranteed.
- Common side effects, and the serious risks specific to that procedure.
- Alternatives, including the alternative of no treatment.
- Whether the use is on-label, off-label, or involves a compounded preparation.
- The number of sessions likely required and the cost implications.
- Aftercare obligations and what the patient must do or avoid.
- Who to contact if something goes wrong, and how, including after hours.
- Opportunity to ask questions, and confirmation that questions were answered.
- Signature and date from the patient and the treating provider — not a receptionist.

PHOTOGRAPHY CONSENT IS SEPARATE

Consent to treatment is not consent to photograph, and consent to clinical photography is not consent to publish. These must be captured as separate, specific authorizations. Marketing use requires its own written authorization stating where images may appear and confirming the patient may revoke it. See OPS-005.

Re-consent triggers

- ☐ Any change in product, device, technique or treatment area.
- ☐ Any change in the risk profile — new medication, new diagnosis, pregnancy.
- ☐ A new provider performing the treatment for the first time.
- ☐ Ongoing therapy: at a defined periodic interval set by the medical director.
- ☐ After any adverse event, before resuming treatment.

4 Chart Standards

Standard	Requirement
Contemporaneous	Entries made at the time of the encounter, not reconstructed later. Where a late entry is unavoidable, label it as a late entry with both dates.
Attributed	Every entry identifies the author by name and role. Shared logins defeat this and should not be used.
Complete	Assessment, consent confirmation, procedure detail, product and lot number, settings or dose, patient response, aftercare given, and follow-up arranged.
Objective	Record observations and actions. Avoid speculation about causation, blame, or commentary about the patient or colleagues.
Corrected by addendum	Never delete, overwrite or obscure an entry. Add a dated addendum stating the correction and the reason.
Legible and accessible	Retrievable within a reasonable time on request by the patient, the medical director, or a regulator.

ALTERING A RECORD

Retrospective alteration of a chart after an adverse event or a complaint is the single most damaging thing a practice can do. Most systems log it, it is usually discovered, and it converts a defensible clinical case into an indefensible credibility case. Addendum only.

5 Retention & Access

- Retention period set by the medical director in line with state record-retention rules — these vary and minors' records are commonly held longer.
- Photographs, consents and communications retained as part of the clinical record.
- Records held securely with access limited to those with a clinical or administrative need.
- Patient access requests handled within the timeframe required by applicable law.
- Secure destruction at end of retention, with a destruction log.
- Continuity plan for records if the practice closes, is sold, or changes systems.

6 Quick Reference

QUICK REFERENCE CARD

Before every treatment

1. **Re-confirm intake.** Medications, allergies, pregnancy, recent changes.

2. **Run the service-specific screen** from the clinical protocol.

3. **Consent for this procedure**, signed by patient and treating provider.

4. **Photography consent** separately — and marketing use separately again.

5. **Chart at the time**, with product, lot, dose or settings recorded.

6. **Record aftercare given** and follow-up arranged.

7. **Corrections by addendum only.** Never overwrite.

Print, laminate and post at the point of care

7 Medical Director Authorization

This protocol is adopted as a standing order for the practice named below. By signing, the medical director confirms the protocol has been reviewed against current clinical guidance, applicable state scope-of-practice rules, and the training level of the staff authorized to perform it.

PRACTICE NAME

LOCATION / SITE

MEDICAL DIRECTOR — PRINTED NAME & CREDENTIALS

LICENSE NUMBER & STATE

SIGNATURE

DATE ADOPTED / NEXT REVIEW DATE

Template notice. This document is an editable template provided for educational and operational guidance. It is not legal advice, does not constitute a physician–patient relationship, and does not guarantee regulatory compliance or the outcome of any inspection. Drug doses, concentrations and device settings must be verified against current manufacturer labeling and prevailing clinical guidance before use. A licensed medical director must review, customize and sign this protocol before it is placed into service, and must confirm that every task assigned within it falls inside the scope of practice of the personnel performing it in your state.

© MedSpa Standards. Licensed for use within the purchasing practice only. Redistribution or resale is prohibited.

OPS-002 Patient Intake, Consent & Medical Records — MedSpa Standards v1.0 · January 2026

Page 4 of 4

OPERATIONS & COMPLIANCE

Scope of Practice, Credentialing & Training

Verifying who may do what, proving they were trained, and keeping it current

DOCUMENT OPS-003	VERSION 1.0	EFFECTIVE January 2026	REVIEW CYCLE Annual
APPLIES TO Practice manager, medical director, all clinical staff	OWNER Medical Director	CLASSIFICATION Confidential	SUPERSEDES All prior versions

1 Purpose & Scope

This protocol answers the question that follows every adverse event: who authorized this person to perform this procedure, and what evidence is there that they were competent to do it. It covers license verification, the service-by-service competency matrix, onboarding, and ongoing review.

TWO SEPARATE QUESTIONS

Scope is what a license permits in your state. **Competency** is whether this particular person can safely do this particular thing. A procedure can be within scope and still be unsafe to delegate. Both need to be documented, and neither substitutes for the other.

2 Credential Verification

When	What is verified	Record
At hire	Primary source verification of license or certification directly with the issuing board — not a photocopy supplied by the candidate. Confirm status, expiry, and any disciplinary history.	Screenshot or printout with the date checked and the name of the verifier.
At each renewal	Re-verification at primary source. Diarize renewal dates in advance rather than discovering a lapse.	Updated verification record; prior records retained.
At hire and annually	BLS certification currency for all clinical staff, and ACLS where the medical director requires it.	Copy of the card with expiry tracked.
At hire	Professional liability coverage where the individual carries their own, plus confirmation of coverage under the practice policy.	Certificate of insurance on file.
Ongoing	Continuing education relevant to the services performed, at the interval required by licensure and by the medical director.	CE log with certificates retained.

A LAPSED LICENSE IS NOT A PAPERWORK PROBLEM

Treatment performed by someone whose license lapsed is generally uninsured, may constitute unlicensed practice, and exposes both the individual and the practice. Renewal tracking is a named person's explicit responsibility, not a shared assumption.

3 Competency Matrix

Build one row per service offered and one column per staff member. Each cell is authorized or not, dated and signed by the medical director. This takes about an hour to populate and answers the hardest question you will be asked.

REQUIRED FIELDS PER AUTHORIZATION

Field	Detail
Service	The specific procedure, at the level of granularity used in your clinical SOPs.
Minimum credential	License level required in your state, plus any device or manufacturer certification.
Training completed	What training, delivered by whom, on what date.
Supervised cases	Number of supervised procedures completed before independent practice, and by whom they were supervised.
Assessment	How competency was assessed — direct observation is the standard.
Authorized by	Medical director signature and date.
Review date	When this authorization is next reviewed.

4 Onboarding a New Clinical Hire

- 1 Verify credentials at primary source** before the first patient contact. No exceptions for experienced hires or short-notice cover.
- 2 Orient to emergency infrastructure.** Kit, AED and oxygen located and the emergency code learned on day one, before any clinical work.
- 3 Issue the protocol set** for the services they will perform. Record that they were issued and read.
- 4 Observation period.** The new hire observes the practice's technique for each service before performing it.
- 5 Supervised practice.** A defined number of cases per service, directly supervised, with each case recorded.
- 6 Competency assessment** by direct observation, against the clinical SOP rather than against habit.
- 7 Medical director authorization** signed into the competency matrix, service by service.
- 8 Enhanced chart review** for a defined initial period, per OPS-001.
- 9 Probation review** at a set date, with any restrictions recorded.

5 Ongoing Review & Scope Boundaries

- ☐ Annual competency review per staff member, per service, signed by the medical director.
- ☐ Re-assessment required after any extended absence from a service.

- ☐ Re-assessment required when a device, product or technique changes materially.
- ☐ Adverse event patterns trigger targeted review rather than an informal conversation.
- ☐ CE requirements tracked with a named owner and advance reminders.
- ☐ Matrix updated within a week of any staffing change.

When a task falls outside authorization

- Staff are explicitly authorized — and expected — to decline any task they are not signed off for, without needing to justify it in the moment.
- Escalate to the supervising provider or medical director rather than proceeding.
- Commercial pressure, a full schedule and an unhappy patient are never grounds to proceed outside authorization. Record the escalation and the outcome.
- Repeated pressure to work outside scope is itself an incident and is reported to the medical director.

MAKE DECLINING SAFE

A competency matrix only works if staff feel able to use it. State plainly, in writing and in onboarding, that declining an unauthorized task is the expected behaviour and will never be held against anyone. Practices where that is not culturally true get the risk anyway, just undocumented.

6 Quick Reference

QUICK REFERENCE CARD

Before anyone treats a patient

1. **License verified at primary source** — not a photocopy.
2. **BLS current** and on file.
3. **Emergency kit, AED and oxygen located** on day one.
4. **Protocols issued and read**, recorded.
5. **Observed, then supervised** for a defined number of cases.
6. **Competency assessed by direct observation.**
7. **Medical director signed the matrix** for that specific service.
8. **Not signed off? Decline and escalate.** Always the right answer.

Print, laminate and post at the point of care

7 Medical Director Authorization

This protocol is adopted as a standing order for the practice named below. By signing, the medical director confirms the protocol has been reviewed against current clinical guidance, applicable state scope-of-practice rules, and the training level of the staff authorized to perform it.

PRACTICE NAME	LOCATION / SITE
MEDICAL DIRECTOR — PRINTED NAME & CREDENTIALS	LICENSE NUMBER & STATE
SIGNATURE	DATE ADOPTED / NEXT REVIEW DATE

Template notice. This document is an editable template provided for educational and operational guidance. It is not legal advice, does not constitute a physician–patient relationship, and does not guarantee regulatory compliance or the outcome of any inspection. Drug doses, concentrations and device settings must be verified against current manufacturer labeling and prevailing clinical guidance before use. A licensed medical director must review, customize and sign this protocol before it is placed into service, and must confirm that every task assigned within it falls inside the scope of practice of the personnel performing it in your state.

© MedSpa Standards. Licensed for use within the purchasing practice only. Redistribution or resale is prohibited.

OPERATIONS & COMPLIANCE

Infection Control, Sterilization & Sharps

Hand hygiene, instrument reprocessing, spore testing, sharps handling and exposure response

DOCUMENT OPS-004	VERSION 1.0	EFFECTIVE January 2026	REVIEW CYCLE Annual
APPLIES TO All staff	OWNER Medical Director	CLASSIFICATION Confidential	SUPERSEDES All prior versions

1 Purpose & Scope

This protocol covers the infection prevention program: hand hygiene, personal protective equipment, treatment room cleaning, instrument reprocessing with biological monitoring, single-use device policy, sharps and medical waste handling, and the response to a bloodborne pathogen exposure.

A DIFFERENT REGULATOR

Much of this sits under occupational safety and public health authority rather than your medical board — different inspectors, different penalties, and obligations that apply to you as an employer regardless of your clinical licensure. Most practices own the autoclave and not the logbook.

2 Hand Hygiene & PPE

Procedure category	Minimum requirement
All patient contact	Hand hygiene before and after every patient encounter, and after glove removal. Alcohol-based rub unless hands are visibly soiled, in which case soap and water.
Injections and skin penetration	Hand hygiene, clean gloves, skin antisepsis at the site, and a clean field. Gloves are changed between patients without exception.
Procedures with splash or spray risk	Add eye protection and a mask. This includes any device generating plume or aerosol.
Instrument reprocessing	Heavy-duty utility gloves, eye protection, mask and a fluid-resistant gown or apron during cleaning.
Plume-generating device use	Smoke evacuation at source plus respiratory protection appropriate to the device — see the laser safety protocol in the Skin & Laser kit.

NAILS, JEWELRY AND SLEEVES

Artificial nails, chipped polish, rings with stones and wrist jewelry all interfere with effective hand hygiene. Set a written standard rather than relying on individual judgement, and apply it to everyone including owners and visiting injectors.

3 Instrument Reprocessing

- 1 **Point-of-use cleaning.** Remove gross soil immediately; do not allow bioburden to dry onto instruments.
- 2 **Cleaning.** Manual or ultrasonic cleaning with an enzymatic detergent. Inadequate cleaning invalidates every step that follows — sterilization does not compensate for it.
- 3 **Inspection and drying.** Inspect for residue and damage. Dry fully before packaging.
- 4 **Packaging.** Appropriate pouches or wrap with a chemical indicator inside each pack and an external process indicator. Label with the date and load identifier.
- 5 **Sterilization.** Run the cycle appropriate to the instrument and packaging. Do not overload the chamber.
- 6 **Cycle verification.** Confirm the cycle completed with correct parameters and the chemical indicator changed. A pack with a failed indicator is not used.
- 7 **Storage.** Store packs clean, dry and protected. Any pack that is wet, torn or dropped is reprocessed.
- 8 **Logging.** Record every load: date, contents, parameters, operator and indicator result.

Biological monitoring

- Spore test run at least weekly, and after every autoclave repair or cycle failure.
- Results recorded and retained with the cycle logs.
- A positive spore test triggers the recall procedure below and the autoclave is removed from service until a repeat test is negative.
- Autoclave serviced and calibrated on the manufacturer's schedule, with records retained.

POSITIVE SPORE TEST — RECALL PROCEDURE

Take the autoclave out of service. Quarantine every pack processed since the last negative test. Identify every patient treated with instruments from those loads. Notify the medical director immediately. Reprocess all quarantined instruments after the unit is repaired and re-tested. The medical director decides on patient notification, and that decision — either way — is documented with its reasoning.

4 Single-Use Devices & Sharps

- ☐ Single-use devices are used once and discarded. Needles, cannulas, microneedling cartridges and disposable tips are never reprocessed, sharpened or shared.
- ☐ Single-dose vials are used for one patient and discarded, even if product remains.
- ☐ Multi-dose vials, where used at all, are dedicated to one patient where possible, dated on opening, and discarded per the beyond-use date.
- ☐ Needles are never recapped by hand; a one-handed technique or a safety device is used where recapping is unavoidable.
- ☐ Sharps containers are puncture-resistant, mounted at point of use, and replaced at the fill line rather than when full.

- ☐ Medical waste segregated, stored securely, and collected by a licensed contractor with manifests retained.
- ☐ Sharps container disposal and waste manifests logged and retained per state requirements.

THE REUSE TEMPTATION

Reprocessing a single-use microneedling cartridge or a filler cannula is a bloodborne pathogen transmission risk, a device labeling violation, and effectively indefensible if it ever comes to light. Cost pressure is not a mitigating circumstance.

5 Exposure Response

- 1 **Immediate first aid.** Wash the site with soap and water. Flush mucous membranes or eyes with water or saline for several minutes. Do not squeeze or scrub the wound.
 - 2 **Report immediately.** To the supervisor and the medical director — the same shift, not the next day. Time matters for post-exposure prophylaxis.
 - 3 **Seek medical evaluation urgently.** Occupational health or emergency department. Post-exposure prophylaxis is time-sensitive and delay reduces its effectiveness.
 - 4 **Document the exposure.** Date, time, location, device involved, circumstances, depth and type of exposure, and PPE in use at the time.
 - 5 **Source patient information** handled in accordance with applicable law and consent requirements. Do not test or disclose outside that framework.
 - 6 **Follow-up testing and counseling** per the evaluating clinician's schedule, tracked to completion.
 - 7 **Investigate and correct.** Identify what allowed the exposure and change it — the device, the technique, the container placement, or the workflow.
- Hepatitis B vaccination offered to all staff with occupational exposure risk, with acceptance or declination documented.
 - Exposure control plan reviewed annually and after any exposure incident.
 - Exposure records retained confidentially and separately from the general personnel file.

6 Environmental Cleaning & Logs

Frequency	Task	Logged
Between patients	Treatment surfaces, chair, headrest and equipment contact points disinfected with an appropriate product at the correct contact time.	No log; observed in audit
Daily	Full room clean, floors, waste removal, replenishment of PPE and supplies.	Daily checklist
Weekly	Spore test; deep clean; expiry sweep of clinical consumables.	Spore log; expiry log
Monthly	Sharps container audit; PPE stock; disinfectant contact-time verification.	Monthly checklist
Annually	Exposure control plan review; infection control training for all staff; autoclave service.	Training and service records

CONTACT TIME IS THE COMMON FAILURE

Surface disinfectants require a specified wet contact time to be effective. Wiping a surface and immediately drying it does not disinfect it. Confirm the contact time for the product you actually use and train to it.

7 Quick Reference

QUICK REFERENCE CARD

Infection control non-negotiables

1. **Hand hygiene** before and after every patient, and after gloves.
2. **Clean before you sterilize.** Bioburden defeats the cycle.
3. **Indicator in every pack**, log every load.
4. **Spore test weekly** and after any repair. Positive → recall procedure.
5. **Single-use means once.** No exceptions, no cost argument.
6. **Never recap by hand.** Sharps container at point of use.
7. **Exposure → wash, report same shift, seek care urgently.**
8. **Respect contact time** on surface disinfectants.

Print, laminate and post at the point of care

8 Medical Director Authorization

This protocol is adopted as a standing order for the practice named below. By signing, the medical director confirms the protocol has been reviewed against current clinical guidance, applicable state scope-of-practice rules, and the training level of the staff authorized to perform it.

PRACTICE NAME	LOCATION / SITE
MEDICAL DIRECTOR — PRINTED NAME & CREDENTIALS	LICENSE NUMBER & STATE
SIGNATURE	DATE ADOPTED / NEXT REVIEW DATE

Template notice. This document is an editable template provided for educational and operational guidance. It is not legal advice, does not constitute a physician–patient relationship, and does not guarantee regulatory compliance or the outcome of any inspection. Drug doses, concentrations and device settings must be verified against current manufacturer labeling and prevailing clinical guidance before use. A licensed medical director must review, customize and sign this protocol before it is placed into service, and must confirm that every task assigned within it falls inside the scope of practice of the personnel performing it in your state.

© MedSpa Standards. Licensed for use within the purchasing practice only. Redistribution or resale is prohibited.

OPERATIONS & COMPLIANCE

HIPAA, Privacy & Marketing Compliance

Safeguards, breach response, before-and-after images, testimonials and advertising claims

DOCUMENT OPS-005	VERSION 1.0	EFFECTIVE January 2026	REVIEW CYCLE Annual
APPLIES TO All staff, marketing personnel and vendors	OWNER Medical Director	CLASSIFICATION Confidential	SUPERSEDES All prior versions

1 Purpose & Scope

Privacy and marketing are combined in one protocol because med spas break both in the same place: a before-and-after posted to social media. This document covers the safeguards protecting patient information, the response when it is disclosed improperly, and the standards governing how treatments and results are advertised.

TWO REGULATORS, ONE POST

An unauthorized before-and-after is a privacy problem. An exaggerated claim about what the treatment achieved is an advertising problem, and in some states a licensing problem too. The same post can be all three.

2 Safeguards

Category	Requirements
Administrative	Named privacy officer. Documented policies. Workforce training at hire and annually. Access granted on a minimum-necessary basis. Access revoked on the day someone leaves. Periodic risk assessment with findings acted upon.
Physical	Screens not visible from waiting or public areas. Charts and paper records secured when unattended. Treatment room doors closed during consultations. Secure destruction of paper containing patient information.
Technical	Individual logins — never shared. Automatic screen lock. Encryption of devices and backups. Secure messaging for anything containing patient information. Audit logging enabled and periodically reviewed.
Vendors	Business associate agreements in place with every vendor that touches patient information: practice management, EMR, billing, cloud storage, transcription, marketing platforms handling patient lists.

The everyday failures

- Discussing a patient where other patients can hear — reception, corridors, the treatment room next door.
- Patient photographs taken and stored on personal phones.
- Text messages and direct messages containing clinical information from personal accounts.
- Responding to an online review in a way that confirms the person was a patient.
- Shared logins that make audit logs meaningless.
- Sign-in sheets and appointment screens visible to other patients.

RESPONDING TO ONLINE REVIEWS

Replying to a negative review by explaining what actually happened during the visit discloses that the person was a patient and discloses clinical detail. Even confirming someone was treated is a disclosure. Respond generically, invite the person to make contact privately, and never engage with the clinical specifics in public — however unfair the review is.

3 Photography & Image Use

Three separate permissions, captured separately, at different times. Bundling them into one signature at intake is the most common error in the field.

Permission	Covers	Notes
Clinical photography	Taking and storing images as part of the medical record.	Part of the clinical record; retained per the record retention schedule.
Internal or educational use	Use in staff training, case review or professional education.	Separate authorization. Specify whether identifying features are shown.
Marketing and publication	Website, social media, advertising, print, third-party platforms.	Separate written authorization. Must state where images may appear, whether the face is shown, and that the patient may revoke it.

- ☐ Clinical images captured on practice-owned devices only, never personal phones.
- ☐ Images stored in the clinical record system, not in a camera roll or a shared drive.
- ☐ Marketing authorization is specific, written, dated and separately signed.
- ☐ Revocation honoured promptly, including removal from platforms where practical, and the request and action documented.
- ☐ Cropping a face out does not make an image de-identified if tattoos, jewelry, scars or background make the person recognizable.
- ☐ Images of minors require parental or guardian authorization, handled with particular care.
- ☐ Authorization records retained for the same period as the clinical record.

4 Advertising & Claims

- Claims must be truthful and substantiated. Results shown must be typical, or the atypical nature must be clearly disclosed.
- Before-and-after images must be unretouched and taken under comparable conditions — same lighting, distance, angle and posing. Retouched comparison images are deceptive.
- Do not guarantee results, and avoid superlatives that cannot be substantiated.
- Disclose material connections in any endorsement — free or discounted treatment in exchange for a post must be disclosed clearly and conspicuously.
- Testimonials must come from real patients, be genuinely held, and never be fabricated, incentivized without disclosure, or edited to change their meaning.
- Off-label uses must not be advertised as approved indications.

- Provider credentials must be represented accurately — title, licensure and specialty. Several states regulate the use of the word 'doctor' and specialty descriptors in aesthetic advertising.
- Pricing and package terms stated clearly, including what is excluded.

FABRICATED REVIEWS

Writing your own testimonials, incentivizing reviews without disclosure, or suppressing negative ones carries direct regulatory exposure — and it is a strange risk to take on a business whose product is credibility. If you do not have real testimonials yet, publish none.

5 Breach Response

- 1 **Contain immediately.** Revoke access, remove the post, recover the device, disable the account — whatever stops further disclosure.
- 2 **Notify the privacy officer and medical director** the same day.
- 3 **Preserve evidence.** Screenshots, logs, timestamps. Do not delete the trail while removing the content.
- 4 **Assess.** What information, how many individuals, who received it, was it encrypted, and has it been mitigated. Document the assessment and its reasoning regardless of the conclusion.
- 5 **Notify** affected individuals and authorities where required, within the applicable timeframes. Timeframes are strict and start early.
- 6 **Document everything** — the incident, the assessment, the decision, the notifications and the dates.
- 7 **Remediate.** Address the root cause and record the corrective action, not just the individual incident.
- 8 **Retrain** where the cause was a workforce action, and record the retraining.

DOCUMENT THE ASSESSMENT EITHER WAY

If you assess an incident and conclude notification is not required, that reasoning must be written down and retained. An undocumented decision not to notify looks identical to never having considered it.

6 Quick Reference

QUICK REFERENCE CARD

Before you post

1. **Separate written marketing authorization** on file — not the intake form.

2. **Practice-owned device** and practice-owned storage only.

3. **Unretouched**, same lighting, distance and angle.

4. **Results typical**, or the atypical nature clearly disclosed.

5. **Material connections disclosed** in any endorsement.

6. **Never respond to a review** with clinical detail.

7. **Revocation honoured promptly** and documented.

8. **Breach: contain, notify the privacy officer same day, preserve evidence.**

Print, laminate and post at the point of care

7 Medical Director Authorization

This protocol is adopted as a standing order for the practice named below. By signing, the medical director confirms the protocol has been reviewed against current clinical guidance, applicable state scope-of-practice rules, and the training level of the staff authorized to perform it.

PRACTICE NAME	LOCATION / SITE
MEDICAL DIRECTOR — PRINTED NAME & CREDENTIALS	LICENSE NUMBER & STATE
SIGNATURE	DATE ADOPTED / NEXT REVIEW DATE

Template notice. This document is an editable template provided for educational and operational guidance. It is not legal advice, does not constitute a physician–patient relationship, and does not guarantee regulatory compliance or the outcome of any inspection. Drug doses, concentrations and device settings must be verified against current manufacturer labeling and prevailing clinical guidance before use. A licensed medical director must review, customize and sign this protocol before it is placed into service, and must confirm that every task assigned within it falls inside the scope of practice of the personnel performing it in your state.

© MedSpa Standards. Licensed for use within the purchasing practice only. Redistribution or resale is prohibited.

OPS-005 HIPAA, Privacy & Marketing Compliance — MedSpa Standards v1.0 · January 2026

Page 4 of 4